

AI Guiding Policy Template

This AI Guiding Policy Template is designed to help organizations craft policies and provisions to ensure sound practices for responsible AI use and integration across the organization.

Note: This document is a sample template intended for general informational purposes only and does not constitute legal or other professional advice. Please consult with qualified professional advisors as necessary to draft appropriate policies for your organization.

[Organization name]

Policy title: AI Guiding Policy

Effective date: [Date]

Last updated: [Date]

Policy owner: [Position or department]

1. Purpose

The purpose of this policy is to establish a guiding framework for the ethical, transparent and responsible use of artificial intelligence (AI) within [Organization name]. This policy ensures that AI technologies are deployed in alignment with our organization's values, legal obligations and stakeholder expectations, while mitigating associated risks.

2. Scope

This policy is designed to work in accordance with other policies and applies to all AI systems and related technologies implemented, developed or maintained by [Organization name], including those developed by third-party vendors. Employees and contingent workers should follow the requirements in this policy to ensure appropriate usage of AI systems and to reduce the likelihood of data confidentiality or integrity risks.

3. Definitions

- **Artificial intelligence (AI):** Technologies that enable machines to perform tasks that typically require human intelligence, such as decision-making, language understanding, visual perception and pattern recognition.
- **AI model:** A component of an information system that implements AI technology and uses computational, statistical or machine-learning techniques to produce outputs from a given set of inputs.
- **AI system:** Any data system, software, hardware, application, tool or utility that operates in whole or in part using AI.
- **Bias:** Any unfair or unequal treatment resulting from the design or implementation of AI models.

4. Guiding principles

All AI projects and activities within [Organization name] must align with the following principles:

- **Sensitive information:** Never put customer or [Organization name] confidential data in any unapproved AI tool.
- **You are responsible and accountable for the outputs of AI:** It is essential to thoroughly review and validate the information before relying on it for any decisions or actions.
- **You should be able to articulate the risks and potential harms of AI before using it:** AI should not be employed in ways that could cause harm (e.g. generating spam) or in sensitive areas where the risks are too great (e.g. making personnel-related decisions).

5. Basic rules for AI usage

Generative AI tools, such as Microsoft Copilot, have been trained to hold human-like conversations and to understand information based on user input and what is published on the internet.

While AI usage represents an opportunity for internal productivity at [Organization name], team members must evaluate whether their intended usage may compromise:

- [Organization name]'s intellectual property.
- Confidentiality of [Organization name] or [Organization name]'s customer data.
- Privacy of [Organization name]'s employees and customers.

6. Risk management

All AI projects must undergo a risk assessment process to identify potential ethical, privacy and security risks by an [AI Oversight Committee] before project approval. High-risk projects may require additional oversight, mitigation steps or third-party audits.

The following risk thresholds apply to all AI systems immediately prior to deployment:

- Systems that remain very high-risk or high-risk post-treatment shall not be allowed to deploy.
- Systems deemed moderate-risk post-treatment shall be subject to more rigorous and frequent testing and monitoring requirements, including impact assessments, than those deemed minimal-risk.

Components of [Organization name]'s risk management process for AI systems are as follows:

1. Impact identification
2. Risk measurement
3. Risk prioritization

4. Risk treatment
5. Residual risk
6. Impact and risk tracking, inventorying and transparency
7. Impact contingency planning and recourse
8. Impact reassessment

7. Data governance

All data used in AI systems should meet the following criteria:

- **Data quality and integrity:** Data used must be accurate, complete and relevant to the intended purpose.
- **Data privacy:** The collection or processing of personal data for AI purposes must adhere to privacy laws and organizational privacy policies.
- **Bias and fairness checks:** Data must be regularly checked to ensure no discriminatory patterns exist.

During the early stages of a project, teams shall identify, characterize and justify the type and quantity of data needed for an AI system.

Rigorous exploratory data analysis shall be conducted for each potential data set to gain insights into underlying structures and statistical properties and to assess alignment with data fit-for-purpose and quality standards.

General information about every selected and utilized data set shall be logged in an enterprise-wide data inventory system, including [e.g. in which projects it is used, internal cross-project usage permissions, data source and contact information, data type and features].

Systems and standards shall be developed by [e.g. functions such as Information Security] to manage the secure and organized storage of data sets enterprise-wide.

For all data sets from third-party sources, project teams shall follow a standard protocol set forth by the procurement team to communicate procurement needs during project scoping and to allow the procurement team to manage the procurement process.

8. Secure AI Usage for Internal Corporate Productivity

Employees and contingent workers must evaluate whether intended usage of AI systems may compromise intellectual property, the confidentiality of [Organization name] or customer data, or the privacy of employees and customers.

Employees and contingent workers are responsible for ensuring they:

- Do not share confidential [Organization name] data or customer data with generative AI tools.

- Review AI responses for accuracy and reliability and do not trust that the tool will be accurate or correct. Some AI tools are prone to “hallucinations” (a confident response by an AI not justified by facts). This is true of fact-based statements as well as code generation.
- In general, avoid sharing personal information of colleagues or customers with AI tools unless an appropriate vendor agreement is in place.

Engaging with AI vendors and systems is subject to standard third-party risk assessment and due diligence. Depending on risk, certain AI vendors may require additional review to ensure they meet requirements for minimizing hallucinations and bias, preserving intellectual property rights, and maintaining appropriate confidentiality, integrity, and general security of data.

9. Secure AI Usage in Product Development

The purpose of this section is to establish guidelines and best practices for the secure development, deployment, and management of AI systems within the company.

The company’s standards for AI development must include requirements for:

- Data collection and preprocessing
- Model selection and training
- Model evaluation and validation
- Model deployment and maintenance
- AI model explainability and transparency
- Secure coding practices

[Organization name] may use AI tools, which include machine learning, generative AI and Large Language Models (LLM), to enhance the value that our products provide customers. The AI models employed by [Organization name] should not be trained on customer data without the customer’s consent. Furthermore, any content produced by [Organization name]’s generative AI should be labeled, allowing users to readily identify AI-generated content.

As with all [Organization name] product functionality, controls must be in place to ensure the logical separation of customer data and no unauthorized third parties are provided access to customer data. The training data and outputs of [Organization name]’s product AI functions should be tested for reliability and trustworthiness.

10. Vendor management

When engaging third-party vendors for AI solutions, [Organization name] will ensure they comply with our AI governance standards by:

- Requiring vendors to disclose algorithms, datasets and model-building processes where feasible.
- Conducting vendor due diligence and risk assessments.
- Mandating regular reporting from vendors on model performance, accuracy and any updates.

11. Monitoring and evaluation

- **Performance monitoring:** AI systems should be regularly monitored to ensure they operate as intended.
- **Post-implementation reviews:** AI systems must undergo periodic reviews to assess continued alignment with ethical and organizational standards.
- **Incident reporting:** Any incidents or deviations from expected AI behavior must be documented and reported to the [AI Oversight Committee].

12. Training and awareness

Employees involved in AI projects shall receive regular training on responsible AI use, data privacy and risk mitigation strategies. The training program will be reviewed annually to incorporate relevant updates to legal and ethical standards relating to AI.

Employees shall be provided with role- and/or system-specific training and educational tools to enable and evaluate their understanding and fulfillment of requirements for AI systems.

Employees shall demonstrate adherence to responsible use policies and processes, including only using approved AI systems as intended.

[Organization name] shall identify deficiencies in AI capacity and skills, identify which gaps can be addressed by training and which are relevant to hiring, and seek new talent as necessary.

13. Compliance

The compliance team shall actively monitor and seek to understand existing and emerging legal and regulatory requirements relevant to all AI activities.

The compliance team shall map the compliance requirements of each AI system, or otherwise develop tools and processes, such as checklists or compliance meetings, to enable technical teams to determine requirements at each stage of a system's life cycle.

The compliance team shall be ultimately accountable for the perceived or realized compliance of every system at each stage of the life cycle, from initial project scoping to post-deployment or post-sale to potential decommission.



Compliance team members shall receive appropriate foundational legal and AI training, developed and distributed by [e.g. the AI Oversight Committee], to enable successful implementation of compliance with AI legal and regulatory requirements across the organization.

The compliance team shall develop role- or system-specific compliance training and other guidance materials for the workforce, with the support of function leadership or system owners, respectively.

14. Review and enforcement of the AI Guiding Policy

This policy will be reviewed annually or more frequently as necessary to address updates in technology, regulations or organizational practices relating to AI. All updates must be approved by the [AI Oversight Committee] and disseminated to relevant stakeholders.

The [AI Oversight Committee] shall be responsible for procedures to detect and respond to deviations and violations of the Policy.

Non-compliance with this policy may result in disciplinary actions, including termination of employment or contract. Contracts with external partners or vendors who fail to adhere to these guidelines may be terminated.

Approval:

Policy Owner: [Position/Name]

Date approved: [Date]